Page No.
Date

Case Study

Securing the University Examination System

A university uses an Operating System-based examination management system to store student records, examination marks, faculty details, and question papers. The system has three main user groups: Students, Faculty, & Administrations. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions and system configuration.

The university has assigned permissions through roles, but an audit review identifies the follo. events:-

- At 10:00, the account Student07 has three failed login attempts.
- At 10:03, Student07 successfully logs in.
- At 10:04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks.xlsx by Student07.
- At 10:15, Faculty02 modifies marks in ExamMarks.xlsx & saves the files successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still alive.

- The audit log is stored on the same server and users with broad permissions may be able to modify or delete it..

The University wants to protect confidentiality, integrity, and availability, prevent unauthorized access; maintain accountability; and investigate ~~suc~~ suspicious activity. You are asked to recommend appropriate operating system access-control, security administrations & auditing measures

Q.1) Identify the main security problems in the case study.

List atleast 4 risks or weaknesses indicated by the scenerio

Q.2) Explain the difference between authentication & authorization using student07 as an example.

Distinguish identity verification ~~for~~ from permission checking.

Q.3] Recommend an access-control policy for students faculty & Administrations. Justify your choices.

Consider how permissions should be assigned & ~~adm~~ managed

Q.4] Prepare a suitable Access Control list (ACL) for ExamMarks.xlsx.

Sto Specify appropriate Read, write, and Delete permissions for each user group

Q.5] Explain how the Principle of Least Privilege should be applied in this system.

State what each group needs to do & which unnecessary permissions should be removed.

Q.6] Interpret the audit events from 10:00 to 10:05. What should the security team to next?

Explain why the sequence is suspicious without assuming that it proves an attack.

Q.7] Identify at least five events that should be recorded in the audit logs.

Include login, file, account, permission, and/or administrative events.

Q.8] Explain why the audit logs must be protected & recommend two ways to protect them.

Consider unauthorized modification, deletion, & investigation.

Q.9] What action should be taken regarding the former faculty member's active account? Explain

Relate your answer to account management & access removal.

Q.10] Suggest a practical Incident-response & corrective-action plan for the university.

Include investigation, access review, policy changes & follow-up monitoring.

→ Answers

Q.1) ① At 10:00 the account student 07 has 3 failed attempts which indicates that there is a password related problem

② At 10:04, student tries to login and attempt to open exammarks.xlsx which includes marks of all the students, student should not have the permission to access marks of all students which is also a security risk.

③ A former administrator account is active which is also a major security weakness.

Q.2] Authentification means verifying the identity of a user. In this case student 07 has 3 failed login attempts. Authorization means the actions which the user is permitted to perform for ex. the faculty members need to view student records & enter or modify marks.

Q.3) The university should use Role-Based Access Control.

As follows :-

Students :- Can view their own marks & download permitted learning materials.

Faculty :- Can view students records & enter or modify marks for their assigned subjects.
Administrators :- Can manage user accounts, permissions & system configurations.

Q.4]

User Groups	Read	write ~~write~~	Delete
Students	Own marks only through an authorized view	NO	NO
Faculty	Yes, for assigned students or subjects	Yes for assigned marks	NO
Administrations	When required for administrations	When required only & authorized	

This Access Control list protects confidential student records. Student cannot modify or delete marks, faculty can update marks & administrators receive only the permissions needed for their duties

Page No.
Date

Q.5] The principle of least privilege means giving users only the permissions they need to perform their work.

1. Students :- Can view their own marks & download permitted study material but cannot modify marks or access other students marks.

2. Faculty :- Can view student records & enter or modify marks but cannot manage user accounts.

3. Administrator :- Can manage user accounts & permissions according to the responsibilities.

4. Formal administrations :- Their account should be immediately deactivited.

Q.6] The sequence of events is suspicious because student 07 makes three failed login attempts at 10:00, successfully logs in at 10:03, attempts to open ExamMarks.xlsx at 10:04, & attempt to modify the file at 10:05.

The security team should
- Receivers login records
- Check whether student 07 walk authorized to access the marks file.
- Investigate whether any marks were actually changed.

Preserve the audit logs & check for other suspicious activities.

Q.7] The system should record:
— Successful & failed login attempts
— Attempts to open or access files
— Changes to student marks
— Changes to roles & access permissions.

These records helps university identify suspicious activities.

Q.8) — Audit logs must be protected because they provides evidence of user activities.
If someone modifies or deletes the logs, the university may lose important evidence during an investigation.

Two ways to protect them are :-
— Restrict access : Only authorized security personnel should be able to manage the logs.
— Use tamper :- resistant storage : Store logs in one separate, protected server.

These measures helps maintain the accuracy.

Q.9) The university should immediately disable the former faculty members accounts & revoke their access to university ~~resources~~ systems.
— It should also terminate active sessions, review the accounts previous activities
Disabling it reduces the risk of unauthorized access & data misuse.

Q.10) Investigate - Review the audit logs, verify student 07's activities & check whether any marks were changed without authentication.

Review access :- Disable the former faculty member account & examine the permissions of students, faculty & administrative.

Monitor regularly : Protect audit logs, review suspicious activities.